Replace and modernize legacy VPN architectures with a cloud-native Zscaler Zero Trust solution to reduce attack surface and lateral movement.

Project Title:

Replace and modernize legacy VPN architectures with a cloud-native Zscaler Zero Trust solution to reduce attack surface and lateral movement.

Program: **Naan Mudhalvan**

Course: **Cyber security**

Team Members:

Member 1 – Moulishwaran.R & 2326J1534

Member 2 – Giridharan.S & 2326J1529

Member 3 – Madhankumar.M.B & 2326J1532

Member 4 – Manies.M & 2326J1533

Member 5 – Gomathi.D & 2326J1530

Institution: **Cheran Arts Science College**

Guide: **Mrs.M.Jeevitha**

Date: **12/03/2026**

Abstract:

Traditional Virtual Private Network (VPN) architectures were designed for an era when most users, applications, and data resided within a centralized corporate network. However, the rapid adoption of cloud services, remote work models, and distributed IT environments has exposed several limitations of legacy VPN solutions, including performance bottlenecks, increased attack surfaces, complex management, and limited scalability. These challenges make traditional perimeter-based security models inadequate for modern enterprise requirements.

This report explores the need to replace and modernize legacy VPN infrastructures by adopting a cloud-native Zero Trust architecture using *Zscaler's Zero Trust Exchange platform*. The Zero Trust model operates on the principle of "never trust, always verify," ensuring that users, devices, and applications are continuously authenticated and authorized before access is granted. Unlike traditional VPNs that provide broad network access once connected, Zero Trust solutions enable secure, identity-based, and application-level access without exposing the internal network.

The report examines the architectural differences between legacy VPN systems and the Zscaler cloud-native security platform, highlighting how Zscaler delivers secure access through a globally distributed cloud infrastructure. Key benefits discussed include enhanced security posture, reduced lateral movement risks, improved user experience, simplified network architecture, and seamless scalability for hybrid and remote work environments.

Furthermore, the report outlines the migration strategy for transitioning from traditional VPN models to a Zero Trust framework, including integration with identity providers, application segmentation, and policy enforcement. Implementation considerations, operational benefits, and real-world use cases are also analyzed to demonstrate how organizations can achieve secure, efficient, and modern network access.

Overall, this report concludes that adopting a cloud-native Zero Trust solution with Zscaler not only mitigates the limitations of legacy VPN architectures but also provides a scalable and resilient security framework suitable for the evolving digital enterprise landscape.

If you want, I can also help you with:

* *Introduction section for the report*

* *Problem statement & objectives*

* *Methodology section*

* *Complete report structure (IEEE / academic format)*.

Use Case Scenarios - Replace and Modernize

1. Secure Remote Workforce Access

Scenario

Employees working from home or remote locations need secure access to internal company applications.

Problem with Legacy VPN

- Users connect to the full corporate network once authenticated.
- If credentials are compromised, attackers gain wide access.
- VPN gateways often become bottlenecks.

Zero Trust Solution

Using a Zero Trust Network Access (ZTNA) model:

- Users authenticate via identity verification.
- Access is granted only to specific applications.
- Continuous monitoring ensures secure sessions.

Output :

- Secure remote access without exposing the internal network.
- Reduced risk of unauthorized access.
- Better performance for remote users.

---

2. Secure Access for Hybrid Workforce

Scenario

Organizations have employees working both in-office and remotely.

Problem with Legacy VPN

- VPN requires backhauling traffic through corporate data centers.
- Causes latency and poor user experience.

Zero Trust Solution

Cloud-native security connects users directly to applications instead of routing traffic through internal networks.

Output :

- Faster access to applications.
- Consistent security policies regardless of location.
- Improved user productivity.

---

3. Third-Party Vendor Access

Scenario

External partners or contractors require limited access to internal systems.

Problem with Legacy VPN

- Vendors often receive full network access.
- Difficult to restrict access to specific resources.

Zero Trust Solution

Access is granted only to the specific applications needed by vendors.

Output :

- Reduced risk of third-party attacks.
- Controlled and monitored vendor access.
- Stronger compliance with security policies.

---

4. Preventing Lateral Movement of Threats

Scenario

A compromised user device attempts to access multiple internal systems.

Problem with Legacy VPN

- Once inside the network, attackers can move laterally.
- Flat network architecture allows threats to spread.

Zero Trust Solution

Each application connection is individually authenticated and verified.

Output :

- Attackers cannot move across systems.
- Breaches are contained quickly.
- Improved threat isolation.

---

5. Secure Cloud Application Access

Scenario

Employees need access to SaaS applications such as CRM, ERP, or collaboration platforms.

Problem with Legacy VPN

- Traffic must pass through VPN and internal networks.
- Increased latency and complexity.

Zero Trust Solution

Users connect directly to cloud applications through secure Zero Trust gateways.

Output :

- Faster cloud access.
- Simplified network architecture.
- Strong security controls for SaaS environments.

STAGE - 1

Project Title:

Replace and Modernize Legacy VPN Architectures with a Cloud-Native Zero Trust Solution

Overview :

1. Assessment of Existing VPN Infrastructure

In this stage, the current VPN-based network architecture is analyzed to understand its structure, security limitations, and performance issues.

Key Activities

- Identify existing VPN gateways and network topology.
- Evaluate security risks such as unauthorized access and lateral movement.
- Analyze user access patterns and application usage.
- Review current security policies and compliance requirements.\

Introduction to Legacy VPN Infrastructure

In traditional enterprise networks, Virtual Private Networks (VPNs) are widely used to provide secure remote connectivity for employees, branch offices, and third-party partners. A VPN extends a private corporate network across a public network such as the internet by creating encrypted communication tunnels between users and internal resources.

Although VPN technology has played a critical role in enabling remote work and secure communication, many organizations still rely on legacy VPN architectures that were designed for older network models. These architectures typically assume that once a user successfully authenticates through the VPN gateway, they are trusted and allowed access to a large portion of the internal network.

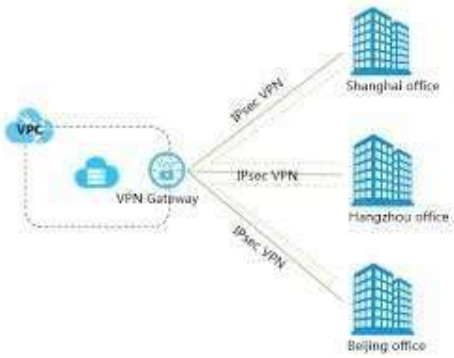
This approach worked well when most employees worked inside corporate offices and security threats were limited. However, modern enterprises now operate in a cloudfirst environment, where users access applications from multiple locations and devices. As a result, traditional VPN systems have become insufficient for modern security requirements.

Stage 1 of the project focuses on performing a comprehensive assessment of the existing VPN infrastructure. This assessment helps organizations understand the current architecture, identify security weaknesses, and determine how the infrastructure should evolve toward a Zero Trust security model.

2. Existing VPN Network Architecture

Legacy VPN environments typically consist of several core components including VPN gateways, authentication servers, network firewalls, and internal application servers. Remote users connect to the corporate network through a VPN client, which establishes an encrypted tunnel to the VPN gateway located at the organization's data center.

Once the connection is established, the user's device becomes part of the internal corporate network and can communicate with internal systems such as databases, file servers, and enterprise applications.



The diagram above illustrates a typical legacy VPN architecture, where remote users connect to a central VPN gateway before accessing corporate resources. In many organizations, branch offices and remote users are connected through IPSec or SSL VPN tunnels that route all traffic through the corporate network.

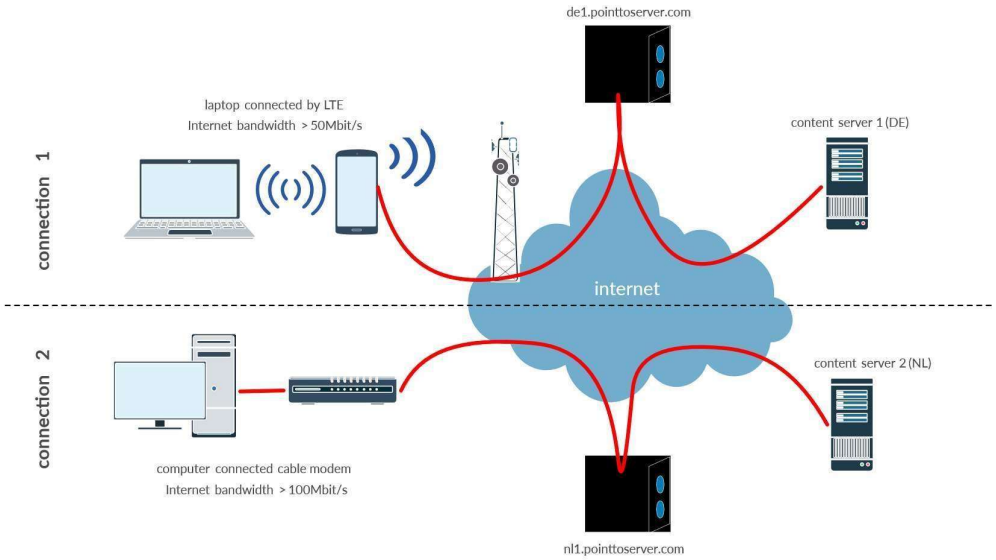
This architecture introduces several challenges:

- All traffic must pass through the corporate data center.
- Network congestion can occur when many users connect simultaneously.
- Security policies are often applied at the network level rather than the application level.

These limitations highlight the need for modern security frameworks such as Zero Trust Network Access (ZTNA).

3. Identification of VPN Gateways and Network Topology

The first technical step in assessing an existing VPN infrastructure is identifying all VPN gateways and network components within the organization's



VPN gateways serve as the entry point for remote connections. These gateways are typically deployed at the network perimeter or within a demilitarized zone (DMZ). Organizations may have multiple gateways deployed across different geographic regions to support remote employees and branch offices.

During the assessment process, network administrators must document the following components:

- VPN gateway locations and configurations
- Network routing architecture
- Firewall and security appliance placement
- Branch office connections
- Cloud network integrations

Understanding the network topology is critical because it reveals how data flows across the organization's infrastructure. Many legacy architectures rely on a hub-and-spoke model, where all traffic is routed through a central data center. While this model simplifies management, it creates a single point of failure and introduces performance bottlenecks.

Here is a Vulnerability List Table (10 items) related to legacy VPN architectures and how moving to a Zero Trust model using Zscaler helps reduce risks such as attack surface and lateral movement.

Legacy VPN Vulnerabilities and Zscaler Zero Trust Mitigation

List of Teammates :

S.No	Name	College	Phone Number
1.	R.Moulishwaran	Cheran Arts Science College	8778015588
2.	S.Giridharan	Cheran Arts Science College	7092121303
3.	M.B.Madhan kumar	Cheran Arts Science College	9943775337
4.	M.Manies	Cheran Arts Science College	9043592238
5.	D.Gomathi	Cheran Arts Science College	9344591819

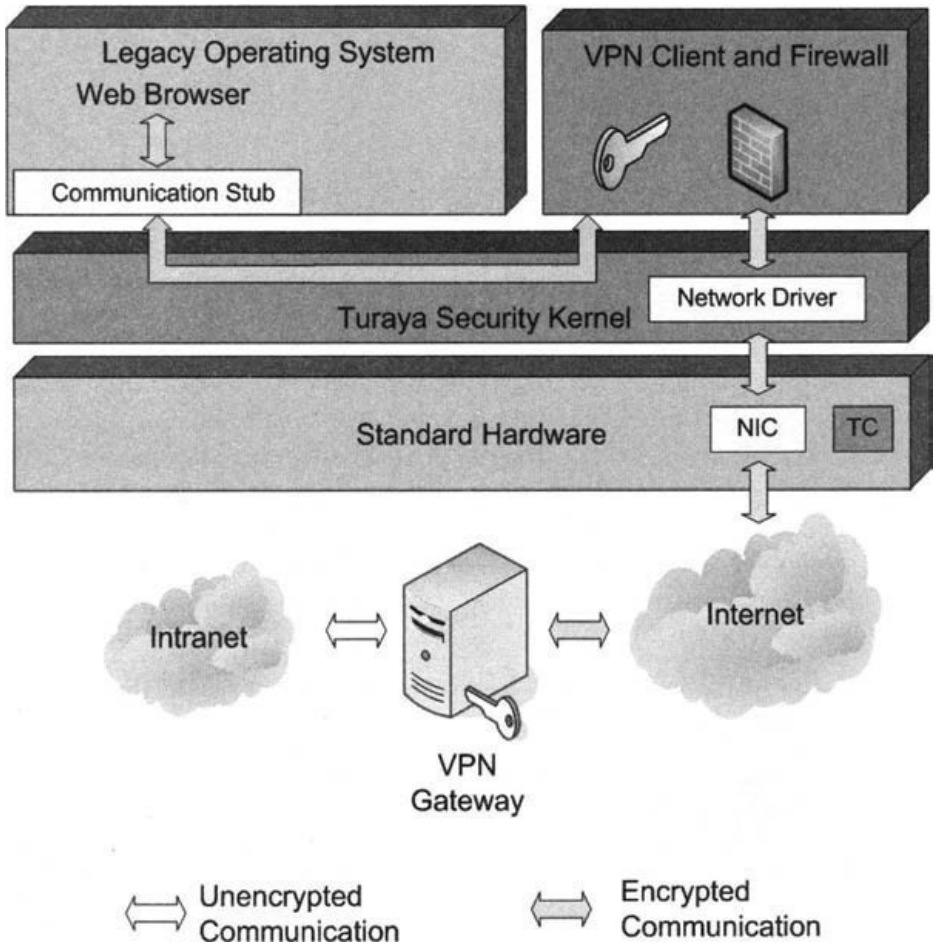
List of Vulnerability Table :

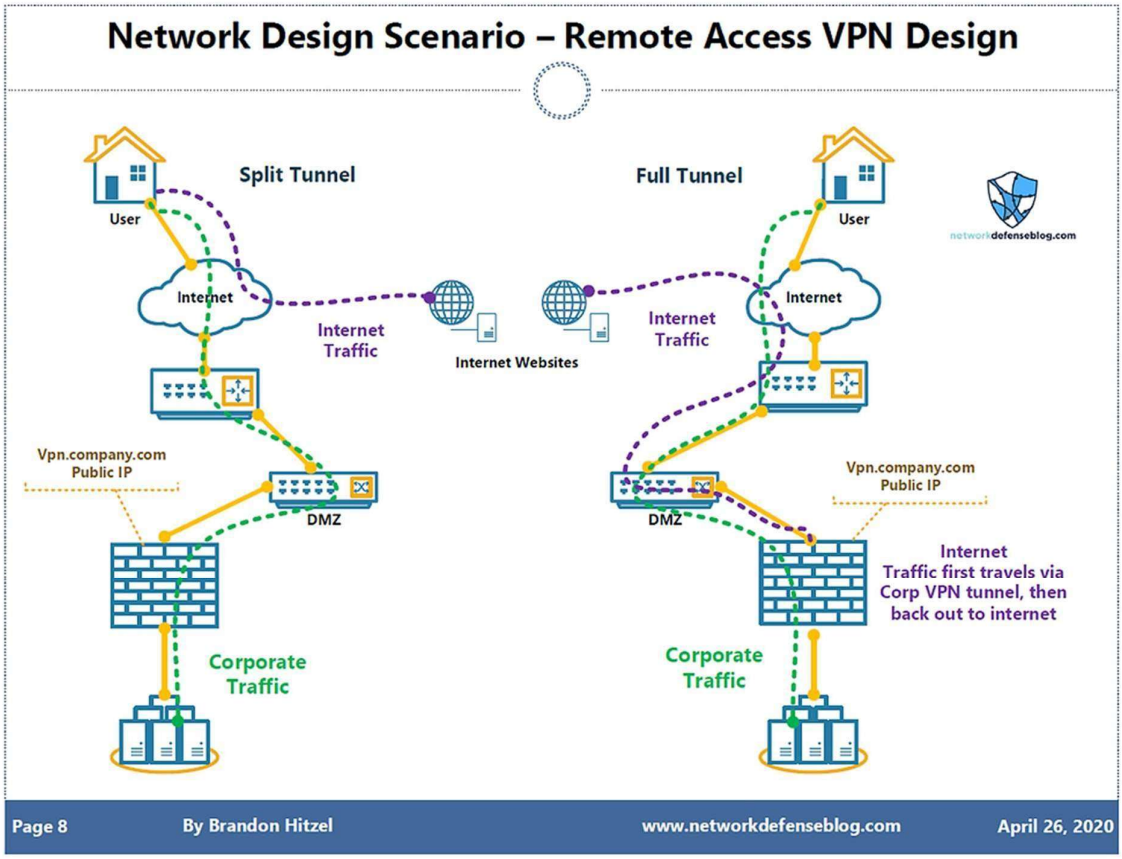
No	Legacy VPN Vulnerability	Simple Description	Zscaler Zero Trust Solution
1	Full Network Access	VPN users can access the entire network after login.	Zscaler gives access only to specific applications.
2	Lateral Movement	Attackers can move to other systems inside the network.	Zero Trust blocks internal movement between systems.
3	Exposed VPN Gateway	VPN servers are visible on the internet. VPN servers are visible on the internet.	Zero Trust blocks internal movement between systems.
4	Weak Authentication	VPN may use only username and password.	Zscaler supports Multi-Factor Authentication (MFA).
5	Unpatched VPN Devices	Old VPN devices may have security vulnerabilities.	Zscaler cloud automatically manages updates and security.

6	Large Attack Surface	Entire network becomes reachable through VPN.	Zero Trust reduces attack surface by limiting access.
7	Poor Monitoring	VPN provides limited user activity monitoring	Zscaler provides better visibility and activity logs

1) Vulnerability Name:

Full Network Access





CWE / CVE:
CWE-284 – Improper Access Control

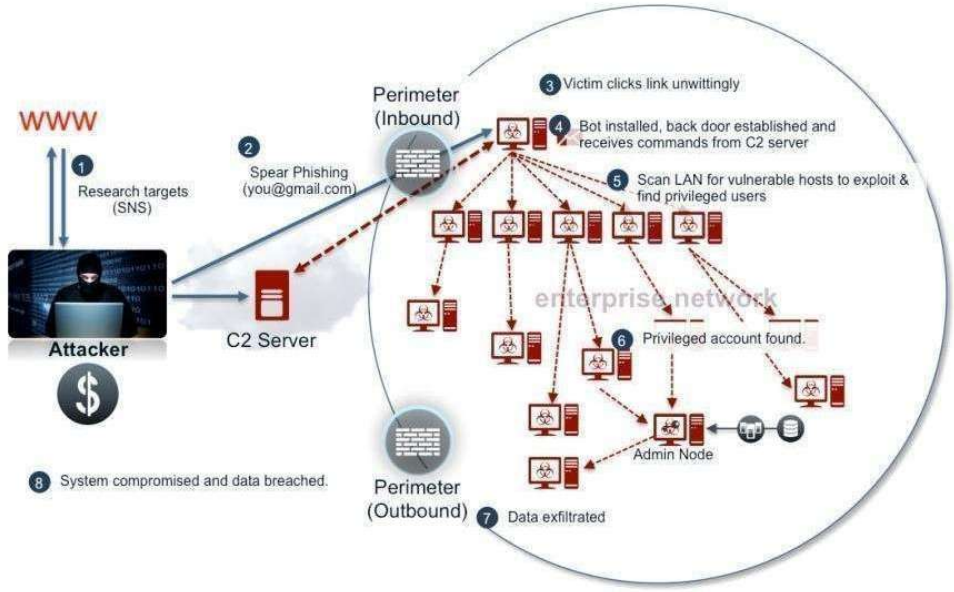
Description:
Traditional VPN solutions provide users with full access to the internal network once they successfully authenticate. Instead of restricting access to specific applications, the VPN tunnel allows users to reach many internal systems and services.

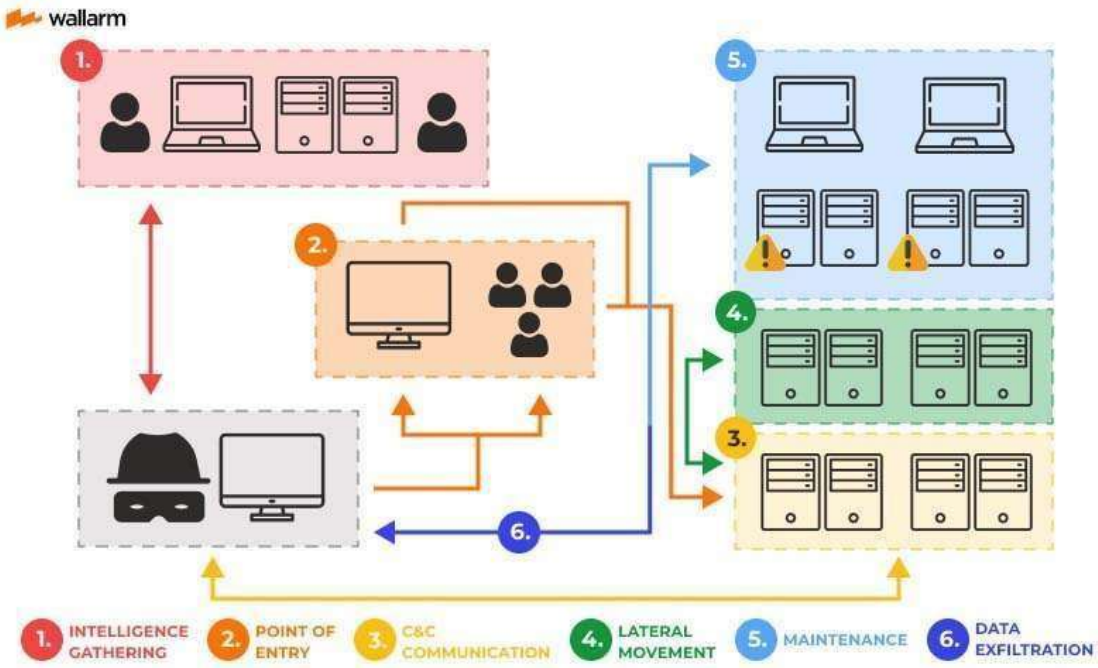
Business Impact:
If an attacker compromises a user's VPN credentials, they can access the entire network infrastructure. This increases the attack surface and may lead to unauthorized data access, system compromise, or large-scale data breaches.

OWASP / SANS Category:
OWASP A5 – Security Misconfiguration

2) Vulnerability Name:

Lateral Movement





CWE / CVE:

CWE-269 – Improper Privilege Management

Description:

Once attackers gain access to a system through VPN credentials or a compromised device, they can move laterally across other systems within the network. This occurs because traditional VPN networks often lack strict segmentation.

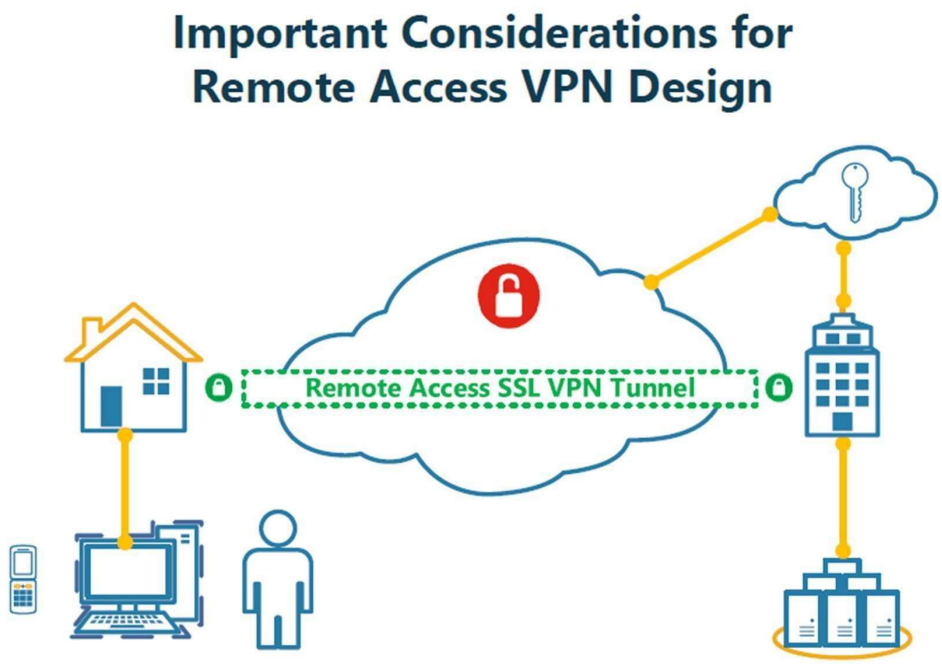
Business Impact:

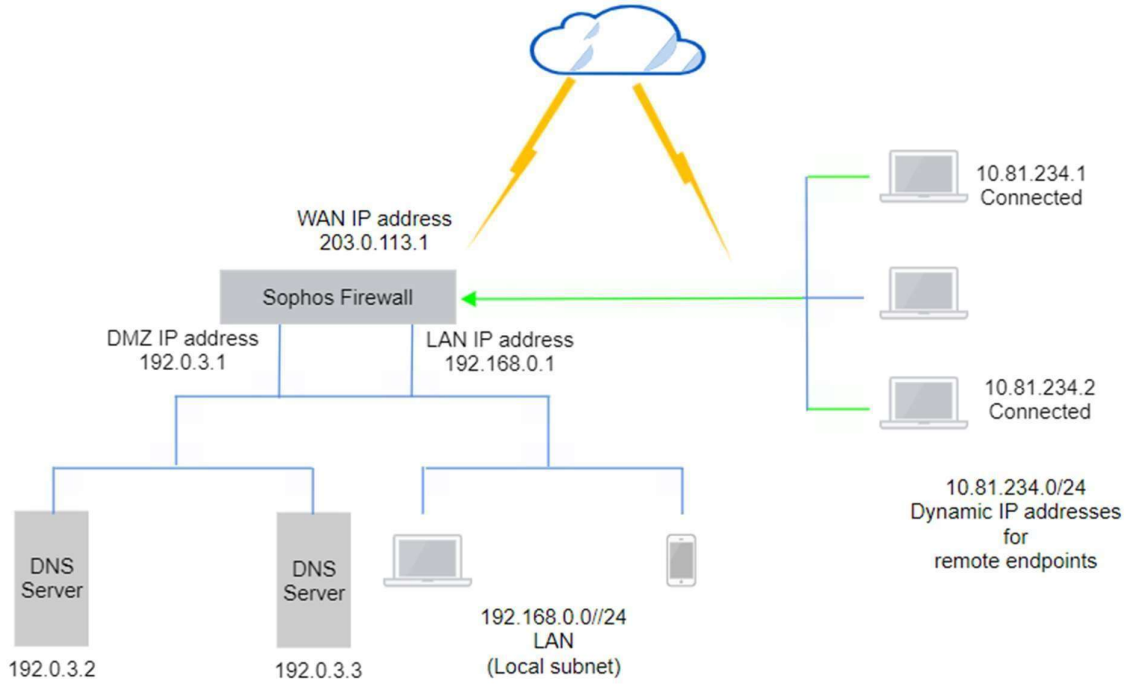
Lateral movement allows attackers to escalate privileges and compromise multiple systems such as databases, servers, and internal applications, leading to major data breaches and operational disruption.

OWASP / SANS Category:
SANS Top 25 – Improper Privilege Management

3) Vulnerability Name:

Exposed VPN Gateway





CWE / CVE:
CWE-284 – Improper Access Control

Description:
VPN gateways must be exposed to the public internet so remote users can connect. Because these gateways are publicly reachable, attackers can scan and attempt to exploit vulnerabilities in the VPN server.

Business Impact:
Attackers may perform brute-force login attempts or exploit known vulnerabilities to gain unauthorized network access. This can lead to data theft, service disruption, and financial losses.

OWASP / SANS Category:
OWASP A5 – Security Misconfiguration

4) Vulnerability Name:

Weak Authentication

CWE / CVE:
CWE-522 – Insufficiently Protected Credentials

Description:
Many legacy VPN systems rely only on username and password authentication. Without additional verification methods, attackers can obtain credentials through phishing, brute-force attacks, or credential leaks.

Business Impact:

Unauthorized users can access sensitive business systems and data, resulting in potential financial loss, regulatory violations, and damage to the organization's reputation.

OWASP / SANS Category:
OWASP A2 – Broken Authentication

5) Vulnerability Name:Unpatched

VPN Devices

CWE / CVE:
CWE-1104 – Use of Unmaintained Components

Description:
Legacy VPN appliances may not receive regular security patches or updates. Attackers can exploit known vulnerabilities in outdated software or firmware to gain unauthorized access.

Business Impact:
Exploiting unpatched devices can lead to system compromise, network downtime, and exposure of sensitive company information, affecting business continuity.

OWASP / SANS Category:
OWASP A6 – Vulnerable and Outdated Components

6) Vulnerability Name

Large Attack Surface

CWE/CVE:
CWE-284 – Improper Access Control

Description:
Legacy VPN architecture exposes large parts of the internal network to remote users.

BusinessImpact:
This increases the chances of **cyberattacks, unauthorized access, and system exploitation**.

OWASP / SANS Category:
OWASP A05:2021 – Security Misconfiguration

7) Vulnerability Name

Poor Monitoring

CWE/CVE:
CWE-778 – Insufficient Logging

Description:
Traditional VPN systems provide limited logging and monitoring of user activity.

BusinessImpact:
Security teams may not detect suspicious behavior quickly, leading to **delayed incident response and greater damage**.

OWASP / SANS Category:
OWASP A09:2021 – Security Logging and Monitoring Failures

Output:

A clear understanding of weaknesses in the legacy VPN architecture and the requirements for modernization.

STAGE - 2

Project Title:

Replace and Modernize Legacy VPN Architectures with a Cloud-Native Zero Trust Solution

Overview :

1. Introduction to Zero Trust Security Strategy

After assessing the limitations of the existing VPN infrastructure in Stage 1, the next step is to design a Zero Trust Security Strategy. The Zero Trust model is a modern cybersecurity approach that assumes no user, device, or application should be trusted by default, even if it is inside the corporate network.

Traditional security models rely on a perimeter-based approach, where users inside the network are considered trustworthy. However, with the growth of cloud computing, remote work, and mobile devices, the network perimeter has become less relevant. As a result, organizations must adopt a security model that continuously verifies every user and device before granting access to resources.

The Zero Trust strategy ensures that every access request is authenticated, authorized, and encrypted, regardless of where the user is located. This stage focuses on defining policies, identifying critical assets, and designing security controls that will guide the implementation of a Zero Trust architecture.

---

2. Core Principles of Zero Trust Architecture

The Zero Trust model is built on three key principles that form the foundation of modern cybersecurity systems.

Verify Explicitly

Every user and device attempting to access a resource must be verified using strong authentication methods. This includes identity verification, device health checks, and behavioral analysis.

Least Privilege Access

Users are granted the minimum level of access required to perform their tasks. This reduces the risk of unauthorized access and limits the potential damage if an account is compromised.

Assume Breach

The Zero Trust model assumes that attackers may already be present within the network. Therefore, security systems are designed to detect suspicious behavior and contain threats quickly.

These principles ensure that security is enforced at every stage of network communication.

3. Zero Trust Architecture Example

The following diagram illustrates how Zero Trust architecture works compared to traditional VPN systems.

In this architecture, users connect to applications through a Zero Trust gateway rather than directly accessing the internal network. Each request is evaluated using identity verification, security policies, and device posture checks before access is granted.

This approach eliminates the need for full network access and significantly reduces the attack surface.

4. Identification of Critical Applications and Data

A crucial step in defining a Zero Trust strategy is identifying critical business applications and sensitive data. Not all applications require the same level of protection, so organizations must classify their resources based on risk and importance.

Examples of critical resources include:

- Financial systems
- Customer databases
- Human resource platforms
- Intellectual property repositories
- Cloud applications and SaaS platforms

By identifying these assets, organizations can prioritize security measures and implement stricter access controls where necessary.

For example, a financial database may require multi-factor authentication and strict monitoring, while a general collaboration tool may require standard authentication.

This classification helps ensure that the most sensitive data receives the highest level of protections.

List of Vulnerabilities :

S.No	Vulnerability Name	Severity	Plugin
1	Full Network Access via Legacy VPN	Critical	VPN Access Control Misconfiguration Plugin
2	VPN Access Control Misconfiguration Plugin	Critical	External Service Exposure Detection Plugin
3	Lateral Movement Across Internal Network	High	Internal Network Segmentation Check Plugin
4	Weak VPN Authentication (Single Factor)	High	Authentication Policy Analyzer Plugin
5	Unpatched VPN Server Software	Critical	Patch Management Scanner Plugin

REPORT :

1) Vulnerability Name: Full Network Access via Legacy VPN

Severity: Critical
Plugin: VPN Access Control Misconfiguration Plugin
Port: 443

Description:
Legacy VPN allows users to access the entire internal network after login.

Solution:
Use Zscaler Zero Trust to allow access only to specific applications.

BusinessImpact:
If attackers steal VPN credentials, they can access many internal systems.

2) Vulnerability Name: VPN Access Control Misconfiguration

Severity: Critical
Plugin: External Service Exposure Detection Plugin
Port: 443

Description:
Improper VPN configuration may allow unauthorized access to internal resources.

Solution:

Apply strict access control policies using Zscaler Zero Trust.

BusinessImpact:
Unauthorized users may access sensitive company information.

3) Vulnerability Name: Lateral Movement Across Internal Network

Severity: High
Plugin: Internal Network Segmentation Check Plugin
Port: Multiple Ports

Description:
Attackers can move between different systems inside the network after VPN access.

Solution:
Use Zero Trust micro-segmentation to restrict internal access.

BusinessImpact:
Attackers can spread malware and compromise multiple systems.

4) Vulnerability Name: Weak VPN Authentication (Single Factor)

Severity: High
Plugin: Authentication Policy Analyzer Plugin
Port: 443

Description:
VPN uses only username and password for login.

Solution:
Enable Multi-Factor Authentication (MFA) with Zscaler.

BusinessImpact:
Hackers can easily access the network using stolen credentials.

5) Vulnerability Name: Unpatched VPN Server Software

Severity: Critical
Plugin: Patch Management Scanner Plugin
Port: 443

Description:
VPN servers that are not updated may contain known security vulnerabilities.

Solution:
Regularly update and patch VPN servers or replace them with Zscaler cloud-based Zero Trust access.

BusinessImpact:
Attackers can exploit vulnerabilities to gain unauthorized access to the network.

STAGE - 3

Project Title:

Replace and Modernize Legacy VPN Architectures with a Cloud-Native Zero Trust Solution

Overview :

1. Introduction

After defining the Zero Trust security strategy in Stage 2, the next step is to design a CloudNative Zero Trust Architecture. This stage focuses on building a secure architecture that replaces traditional VPN-based connectivity with a modern cloud security framework.

In a cloud-native Zero Trust architecture, users no longer connect directly to the corporate network. Instead, they securely connect to specific applications through a cloud-based security platform. Every request is verified based on identity, device health, and security policies before access is granted.

This approach ensures that sensitive applications and data remain protected while allowing employees to work securely from anywhere.

---

2. Architecture Overview

The cloud-native Zero Trust architecture is designed to eliminate the traditional network perimeter and replace it with identity-driven access control.

In this architecture:

- Users connect through a secure Zero Trust gateway.
- Authentication is verified using identity management systems.
- Security policies determine what applications users can access.
- Applications remain hidden from the public internet.

Example Architecture Diagram

The diagram shows how users connect securely to applications through a Zero Trust cloud platform, which verifies identity and enforces security policies before allowing access.

---

3. Key Components of Cloud-Native Zero Trust Architecture

A Zero Trust architecture consists of several important components that work together to ensure secure access.

3.1 Identity Provider (IdP)

The Identity Provider is responsible for verifying user identities. It integrates with systems such as:

- Active Directory
- Cloud identity platforms
- Multi-factor authentication systems

This ensures that only authenticated users can request access to applications.

3.2 Zero Trust Access Gateway

The Zero Trust Gateway acts as a secure intermediary between users and applications. Instead of exposing internal systems directly to users, all traffic passes through this gateway.

The gateway performs several important functions:

- Authentication verification
- Policy enforcement
- Encryption of communication
- Monitoring of user activity

This helps protect applications from unauthorized access.

3.3 Policy Engine

The policy engine is responsible for making real-time access decisions based on predefined security rules.

These policies may consider:

- User identity
- Device security posture
- Geographic location
- Time of access
- Risk level of the request

The policy engine ensures that only authorized users can access specific resources.

3.4 Application Connectors

Application connectors create a secure connection between internal applications and the Zero Trust platform.

These connectors ensure that:

- Applications remain hidden from the internet
- Access is granted only through authenticated connections
- Direct network exposure is eliminated